ONE-PAGE BRIEF

Post-quantum cryptography review: jade @ a59d14c2b397

Client: Blockstream (Jade) — public repository (passive review) · Source: github.com/Blockstream/Jade, commit `a59d14c2b397` · Reviewed: 2026-11-04 18:49 UTC · Risk profile: Crypto exchange, custodian or wallet

POST-QUANTUM MATURITY

Level 0 of 4

no post-quantum cryptography

FINDINGS

0 Critical **2** High **18** Medium **0** Low **2** Info

QUANTUM TIMELINE (MOSCA: X + Y − Z)

Key establishment: 10 + 5 − 8 = 7 → **too late**

Signatures: 10 + 5 − 8 = 7 → **too late**

Next step: Inventory where classical public-key cryptography protects long-lived data and keys, and choose the first migration: usually a hybrid TLS key exchange and wrapped keys.

WHAT MATTERS MOST

High	QSI-2026-11963	**Private key material present in tools/fakeprod_attest.pem** What to do: Treat the key as compromised: rotate it, revoke associated certificates, remove it from version history and store keys in a secrets...
High	QSI-2026-11964	**Private key material present in tools/fakeprod_v2.pem** What to do: Treat the key as compromised: rotate it, revoke associated certificates, remove it from version history and store keys in a secrets...
Medium	QSI-2026-11947	**Quantum-vulnerable RSA key (4096-bit) in SECURITY.md** What to do: Inventory and plan migration to ML-DSA (FIPS 204) or SLH-DSA (FIPS 205), in a hybrid/ composite form where the ecosystem supports it..
Medium	QSI-2026-11956	**Quantum-vulnerable RSA key (3072-bit) in release/scripts/dev_fw_pub_key_A.pub** What to do: Inventory and plan migration to ML-DSA (FIPS 204) or SLH-DSA (FIPS 205), in a hybrid/ composite form where the ecosystem supports it..

16 more in the full report.

WHAT THE QUANTUM-VULNERABLE CRYPTOGRAPHY PROTECTS

Role	Algorithms	What to do
Medium firmware and boot verification (root of trust)	ECDSA	Plan a hybrid firmware signature (the classical one plus ML-DSA or SLH-DSA, both required) and the path to...
Medium key wrapping and data encryption at rest	ECDH	Wrap keys with ML-KEM or a hybrid KEM (X25519 + ML-KEM-768) and re-wrap the stored keys; data that may...
Medium transaction and message signing	ECDSA, Schnorr (BIP-340)	Follow each chain's post-quantum roadmap, avoid public-key reuse, and keep signers ready to add post-quantum...
Medium authentication and identity (certificates, tokens, device attestation)	ECDSA, RSA	Keep credentials short-lived and plan ML-DSA certificates, tokens and keys as the ecosystem supports them

Static review of source code and manifests; files analysed: 737. No requests were sent to the owner's systems.

Full report, content SHA-256: `c63d3d7f217a30d4175e240476737e24cdf4757b3c18c2f58beef44c0fed6714`

Full report signature (report.sig.json): Ed25519 key, SHA-256 fingerprint `5b3cf9c9bd0fa54447e2b5dfa7a6bab569bd0c666fa46949599e5c348d17083e`. bundle.sig.json lists the SHA-256 of every file in this bundle and is signed too; verify-bundle checks it offline.

Preliminary findings need confirmation in the code; the full report gives the evidence, the limits of each check and how to re-test.